

Symmetric Key Distribution: Symmetric Key Distribution Using Symmetric Encryption

Chapter-8: Key Management and Distribution

Dr. Bhasha Anjaria

Assistant Professor

Department of Computer Science and Engineering

Content

1. Symmetric Key Distribution: Symmetric Key Distribution Using Symmetric Encryption
2. Symmetric Key Distribution Using Asymmetric Encryption
3. Asymmetric Key Distribution: Distribution of Public Keys
4. X.509 certificates
5. Advanced Topics: Firewall, Intruders, Virus, Trojans, Malware, Ransomware

Symmetric Key Distribution Using Symmetric Encryption

- Key distribution is the function that **delivers a key to two parties** who wish to **exchange secure encrypted data**.
- Some sort of mechanism or protocol is needed to provide the secure distribution of keys.
- Key distribution often involves the use of
- **Master keys**, which are infrequently used and are long lasting.
- **Session keys**, which are generated and distributed for temporary use between two parties.

Symmetric Key Distribution Using Symmetric Encryption

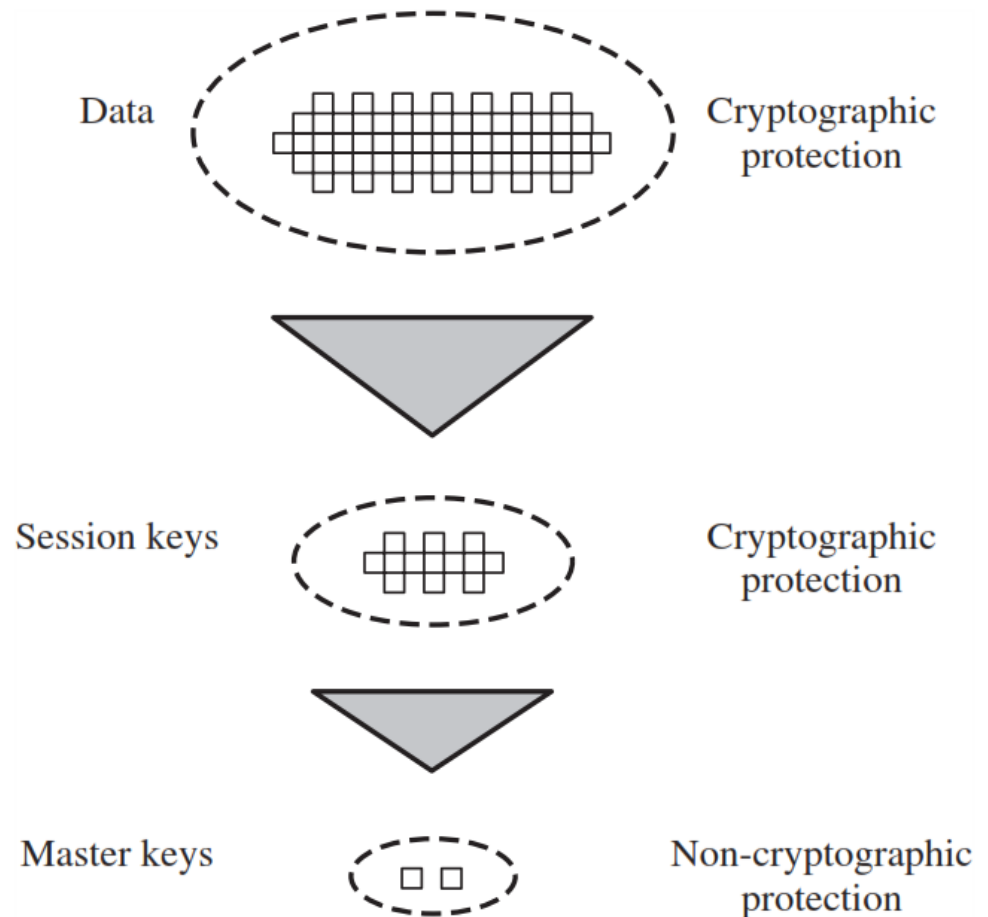
- **Objective:** Two entities share same secret key.
- **Principle:** Change keys frequently.
- How to exchange a secret key?
- For two parties **A and B**, key distribution can be achieved in a number of ways, as follows:
 1. **A** can select a key and **physically deliver** it to **B**.
 2. **Third party** can select the key and **physically deliver** it to A and B.
 3. If **A and B have previously and recently used a key**, one party can transmit the new key to the other, encrypted using the old key.
 4. If **A and B** each has an encrypted connection to a **third party C**, C can deliver a key on the encrypted links to A and B.

Symmetric Key Distribution Using Symmetric Encryption

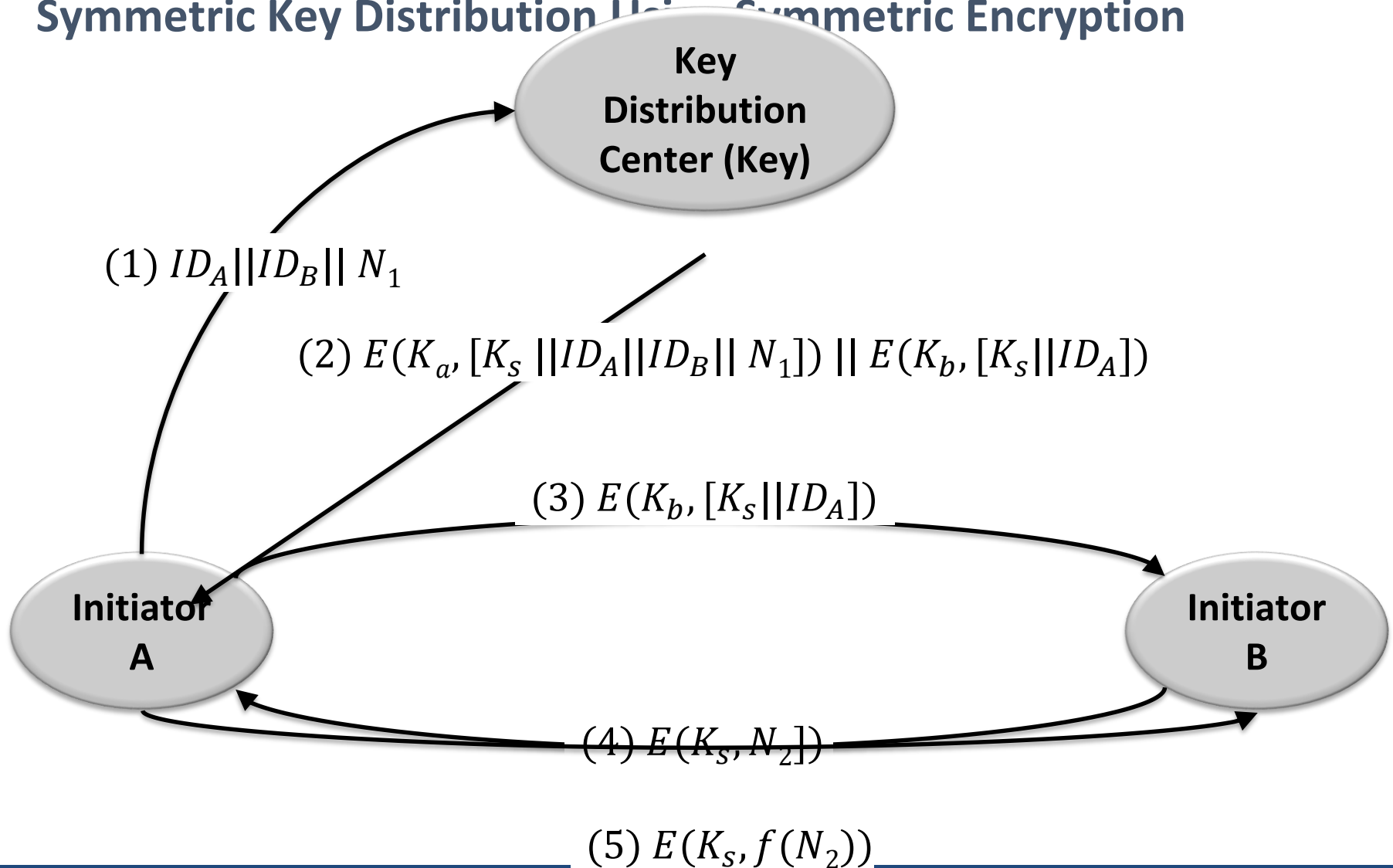
- Key Distribution Centre (KDC) is trusted third party.
- Hierarchy of keys used:
 - Data sent between end-systems are encrypted with temporary session key.
 - Session keys obtained from KDC over network are encrypted with master key.
 - Master keys can be distributed using manual delivery.

Symmetric Key Distribution Using Symmetric Encryption

- Communication between end systems is encrypted using a temporary key, often referred to as a session key.
- Session keys are transmitted in encrypted form, using a master key that is shared by the key distribution center and an end system or user.



Symmetric Key Distribution Using Symmetric Encryption



Symmetric Key Distribution Using Symmetric Encryption

- **End-systems:** A and B, identified by IDA and IDB.
- **Master keys:** K_a , K_b
- **Session key** (between A and B): K_s
- **Nonce values:** N_1 , N_2
 - E.g., timestamp, counter, random value.
 - Must be different for each request.
 - Must be difficult for an attacker to guess.

Symmetric Key Distribution Using Symmetric Encryption

1. A issues a requests to the KDC for a session key to protect a logical connection to B. The message includes the identity of A and B and a unique nonce N1.
2. The KDC responds with a message encrypted using K_a that includes:
 - I. One-time session key K_s to be used for the session.
 - II. The original request message to enable A to match response with appropriate request.
 - III. Information for B.

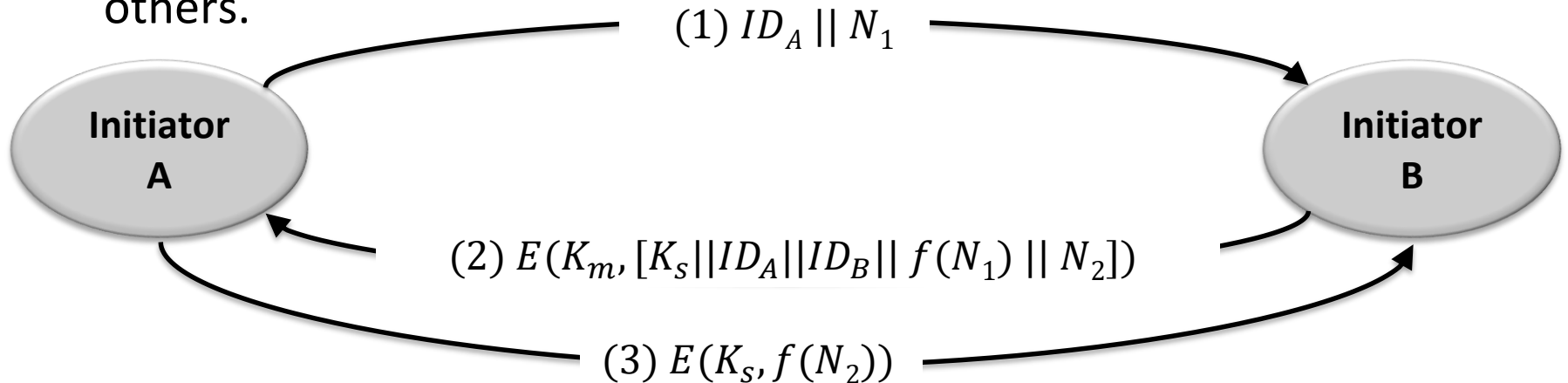
Symmetric Key Distribution Using Symmetric Encryption

4. A stores the session key for use in the upcoming session and forwards to B the information from the KDC for B, namely, $E(K_b, [K_s || [ID]_A])$.
5. B sends a nonce N_2 to A using the new session key.
6. A responds with $f(N_2)$ using K_s .

Last two steps assure B, that, the original message it received (step 3) was not a replay.

Symmetric Key Distribution Using Symmetric Encryption

- Alternative option that doesn't rely on KDC.
- Each end-system must manually exchange $n-1$ master keys (K_m) with others.

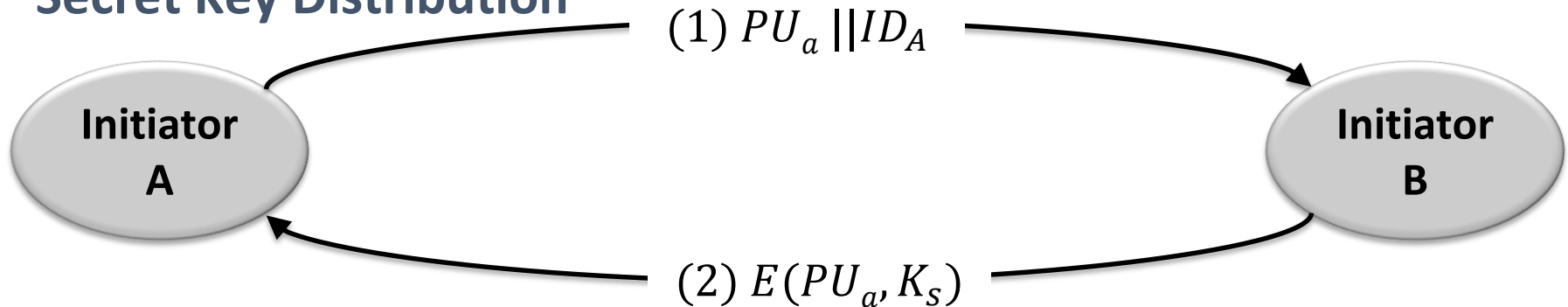


1. A issues a request to B for a session key and includes a nonce.
2. B responds with a message that is encrypted using the shared master key.
3. A returns $f(N_2)$ to B using the new session key.

Symmetric Key Distribution using Asymmetric Encryption

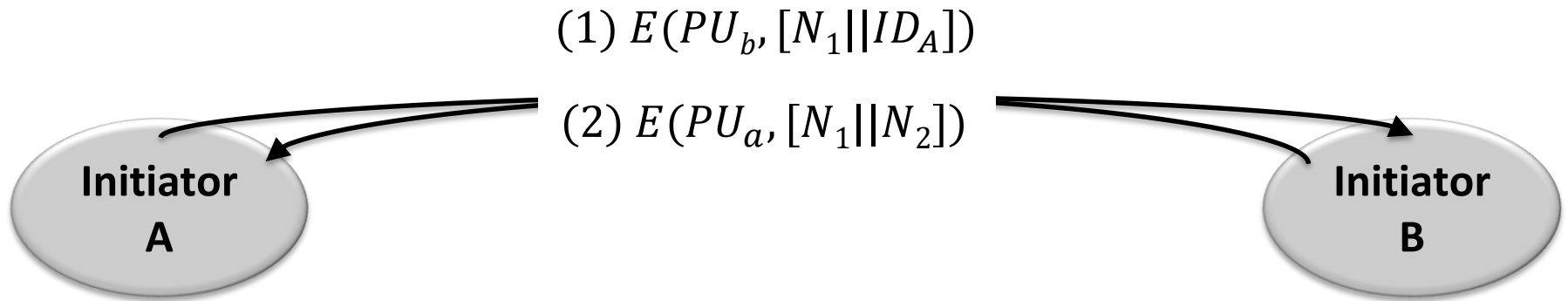
- Common application of asymmetric encryption is exchanging secret keys.
- Two examples:
 1. Simple Secret Key Distribution.
 2. Secret Key Distribution with Confidentiality and Authentication.

Symmetric Key Distribution using Asymmetric Encryption – Simple Secret Key Distribution



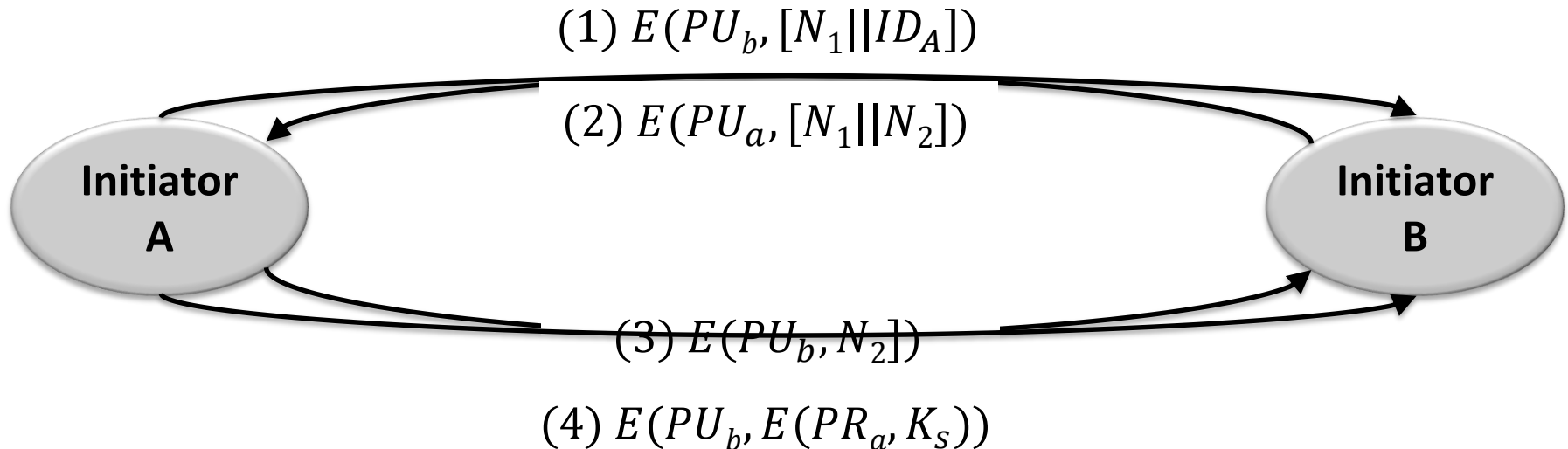
1. **A** generates a public/private key pair **{PUa, PRa}** and transmits a message to **B** consisting of **PUa** and an identifier of **A**, **IDA**.
2. **B** generates a secret key, **Ks** and transmits it to **A**, encrypted with **A's** public key.
3. **A** computes **D(PRa, E(PUa, Ks))** to recover the secret key. Only **A** can decrypt the message because only **A** and **B** will know the identity of **Ks**.
4. **A** discards **PUa** and **PRa** and **B** discards **PUa**.

Symmetric Key Distribution using Asymmetric Encryption



1. **A** uses **B's public key** to encrypt a message to **B** containing an identifier of **A**(**IDA**) and a **nonce (N1)**, which is used to identify this transaction uniquely.
2. **B** sends a message to **A** encrypted with **PUa** and containing **A's (N1)** as well as a new nonce generated by **B(N2)**. The presence of **N1** in message (2) assures **A** that the correspondent is **B**.

Symmetric Key Distribution using Asymmetric Encryption



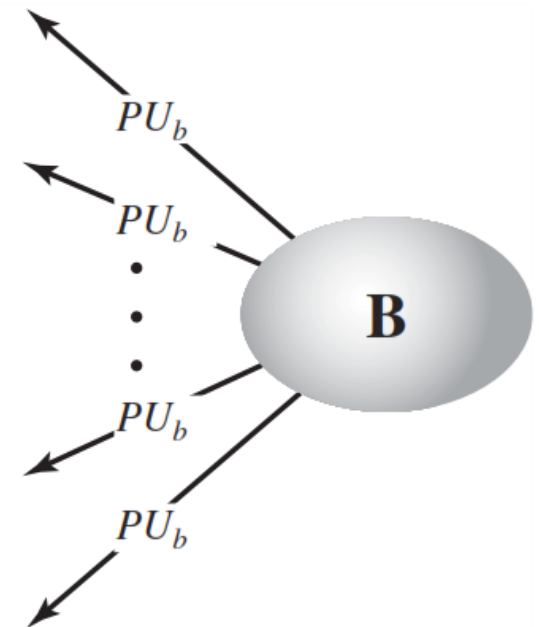
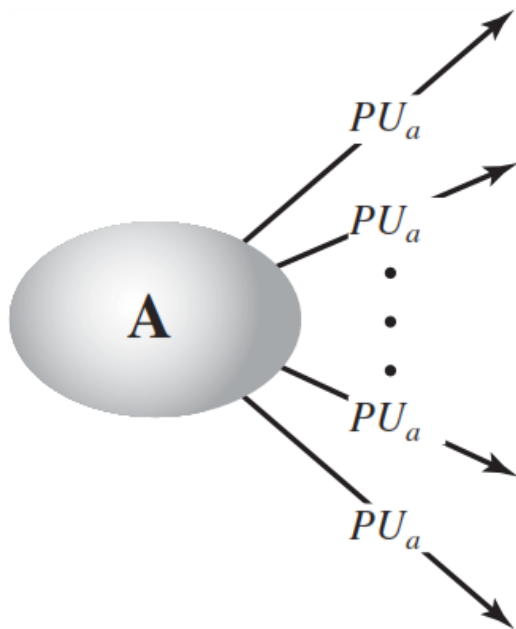
3. **A** returns **N2**, encrypted using **B's** public key, to assure **B** that its correspondent is **A**.
4. **A** selects a secret key **Ks** and sends **M = E(PUb, E(PRa, Ks))** to **B**. Encryption with **B's** public key ensures that only **B** can read it; encryption with **A's** private key ensures that only **A** could have sent it.
5. **B** computes **D(PUa, D(PRb, M))** to recover the secret key.

Distribution of Public Keys

- Public keys are made public by design.
- Issue: how to ensure public key of A actually belongs to A (and not someone pretending to be A).
- Four approaches for distributing public keys
 1. Public announcement
 2. Publicly available directory
 3. Public-key authority
 4. Public-key certificates

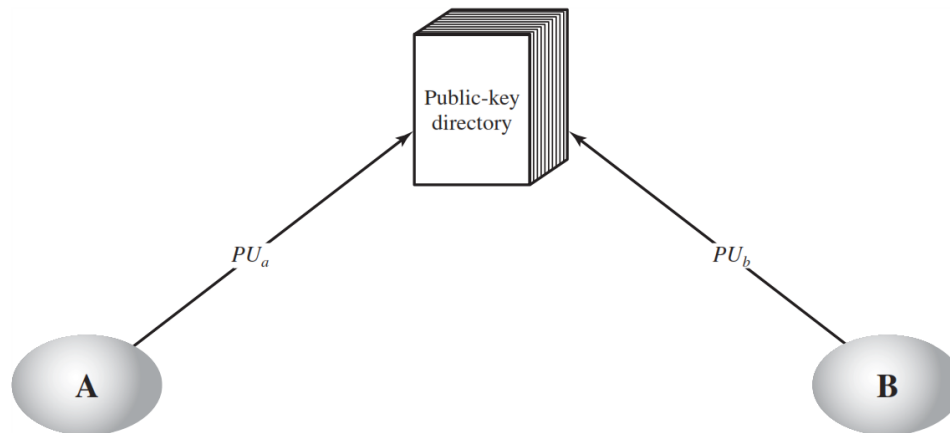
Distribution of Public Keys - Public announcement

- Make **public key available in open forum**: newspaper, email signature, website and conference.
- Problem: anyone can announce a key pretending to be another user.

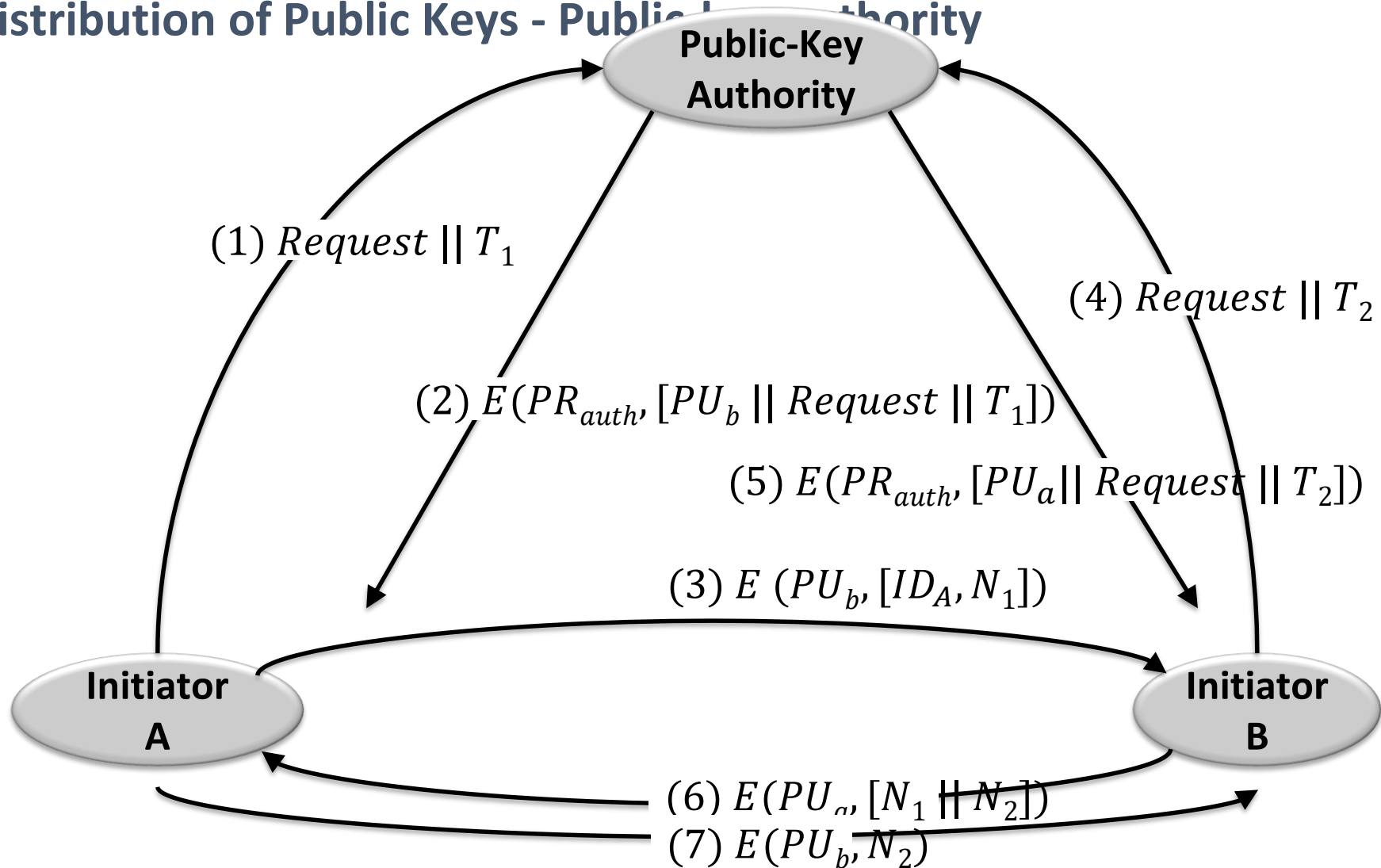


Distribution of Public Keys - Publicly available directory

- The authority maintains a directory with a {name, public key} entry for each participant.
- Each participant registers a public key with the directory authority.
- A participant may replace the existing key with a new one at any time.
- Participants could also access the directory electronically. For this purpose, secure, authenticated communication from the authority to the participant is mandatory.



Distribution of Public Keys - Public Key Authority



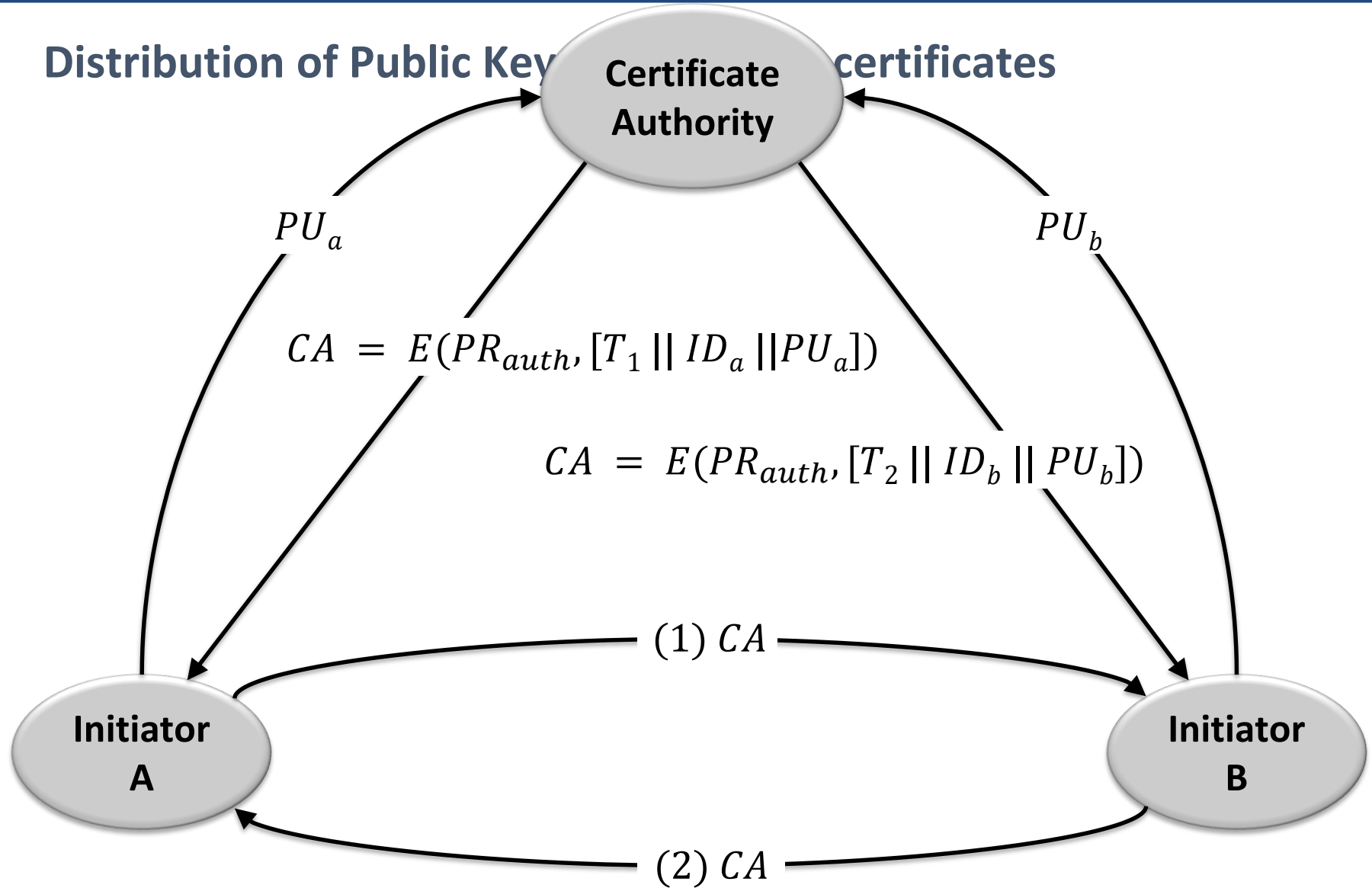
Distribution of Public Keys - Public-key authority

1. **A** sends a timestamped message to the public-key authority containing a request for the current public key of **B**.
2. The authority responds with a message that is encrypted using the authority's private key. Message contains **PU_b**, Original request and Original time stamp **T1**.
3. **A** stores **B's public key** and also uses it to encrypt a message to **B** containing an identifier of **A(ID_a)** and a **nonce(N1)**.
4. **B** retrieves **A's public key** from the authority in the same manner as **A** retrieved **B's public key**.
6. **B** sends a message to **A** encrypted with **PU_a** and containing **A's nonce(N1)** as well as a **new nonce generated by B(N2)**. The presence of **N1** in message (6) assures **A** that the correspondent is **B**.
7. **A** returns **N2**, which is encrypted using **B's public key**, to assure **B** that its correspondent is **A**.

Distribution of Public Keys - Public-key certificates

- Any participant can **read a certificate** to determine the name and public key of the certificate's owner.
- Any participant can **verify** that the **certificate originated** from the **certificate authority** and is not counterfeit.
- Only the **certificate authority** can **create and update** certificates.
- Any participant can verify the currency of the certificate.

Distribution of Public Key certificates



Distribution of Public Keys - Public-key certificates

- Each participant applies to the **certificate authority**, supplying a public key and requesting a certificate.
- For participant **A**, the authority provides a certificate of the form

$$CA = E (PRauth, [T || IDa || \llbracket PU \rrbracket_a])$$

- **A** may then pass this certificate on to any other participant, who reads and verifies the certificate as follows:

$$= D(PUauth, CA)$$

$$= D(PUauth, E (PRauth, [T || IDa || \llbracket PU \rrbracket_a]))$$

$$= (T || IDa || \llbracket PU \rrbracket_a)$$

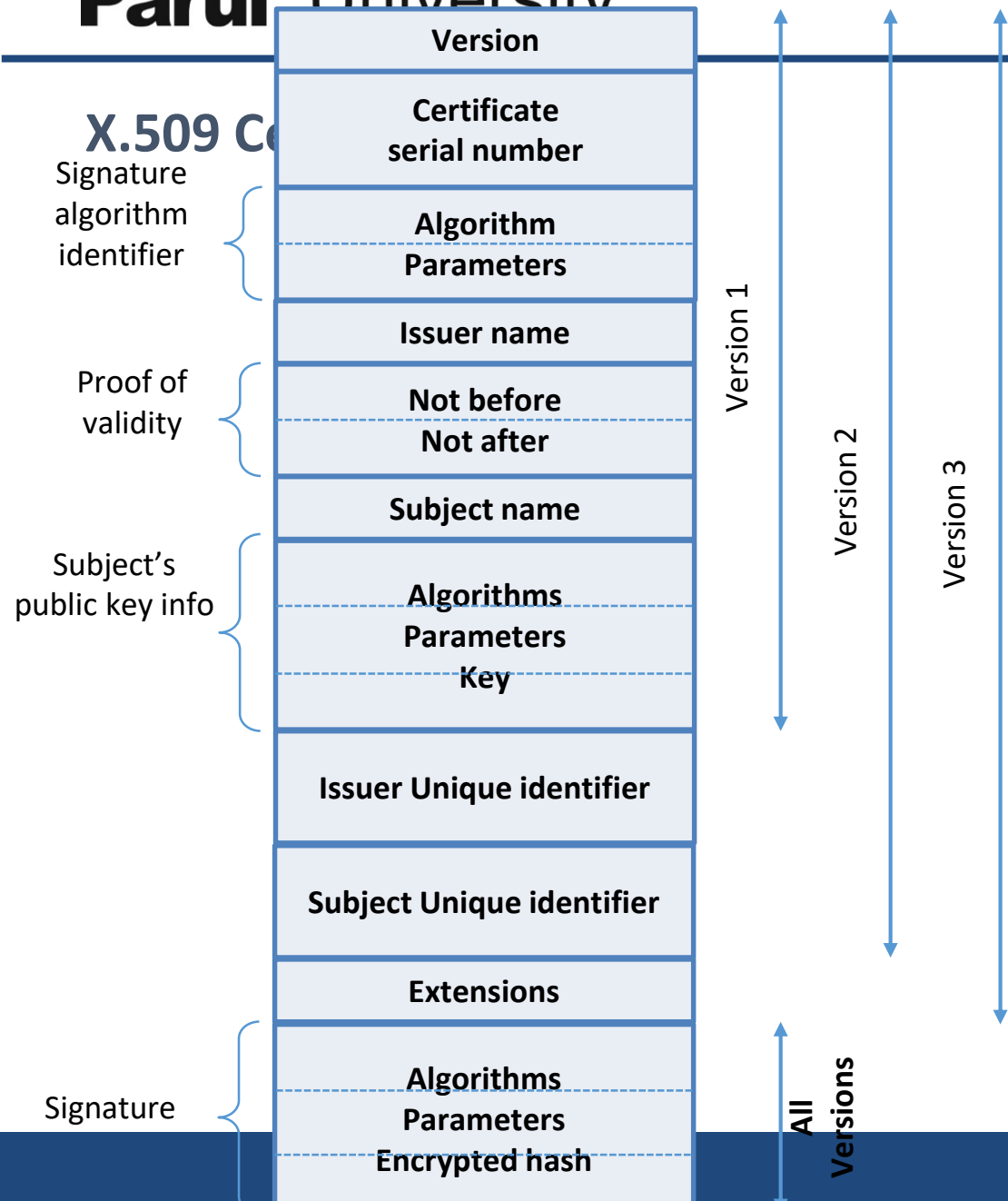
X.509 Certificate

An X.509 certificate is a **digital certificate** that uses the widely accepted international **X.509 public key infrastructure** (PKI) standard to verify that a public key belongs to the user, computer or service identity contained within the certificate.

X.509 defines the format for public-key certificates used in a variety of applications.

The directory may serve as a repository of public-key certificates.

Each certificate contains the **public key of a user** and is **signed with the private key** of a trusted certification authority.



X.509 Certificate

Version: Differentiates among successive versions of the certificate format; the default is version 1.

Serial number: The identity creating the certificate must assign it a serial number that distinguishes it from other certificates.

Signature algorithm identifier: The algorithm used by the issuer to sign the certificate.

Issuer name: The name of the entity issuing the certificate (usually a certificate authority).

Period of validity: Consists of two dates: the first and last on which the certificate is valid.

X.509 Certificate

Subject's public-key information: The public key associated with the identity.

Issuer unique identifier: An optional-bit string field used to identify uniquely the issuing Certificate Authority (CA).

Subject unique identifier: An optional-bit string field used to identify uniquely the subject name.

Extensions: A set of one or more extension fields.

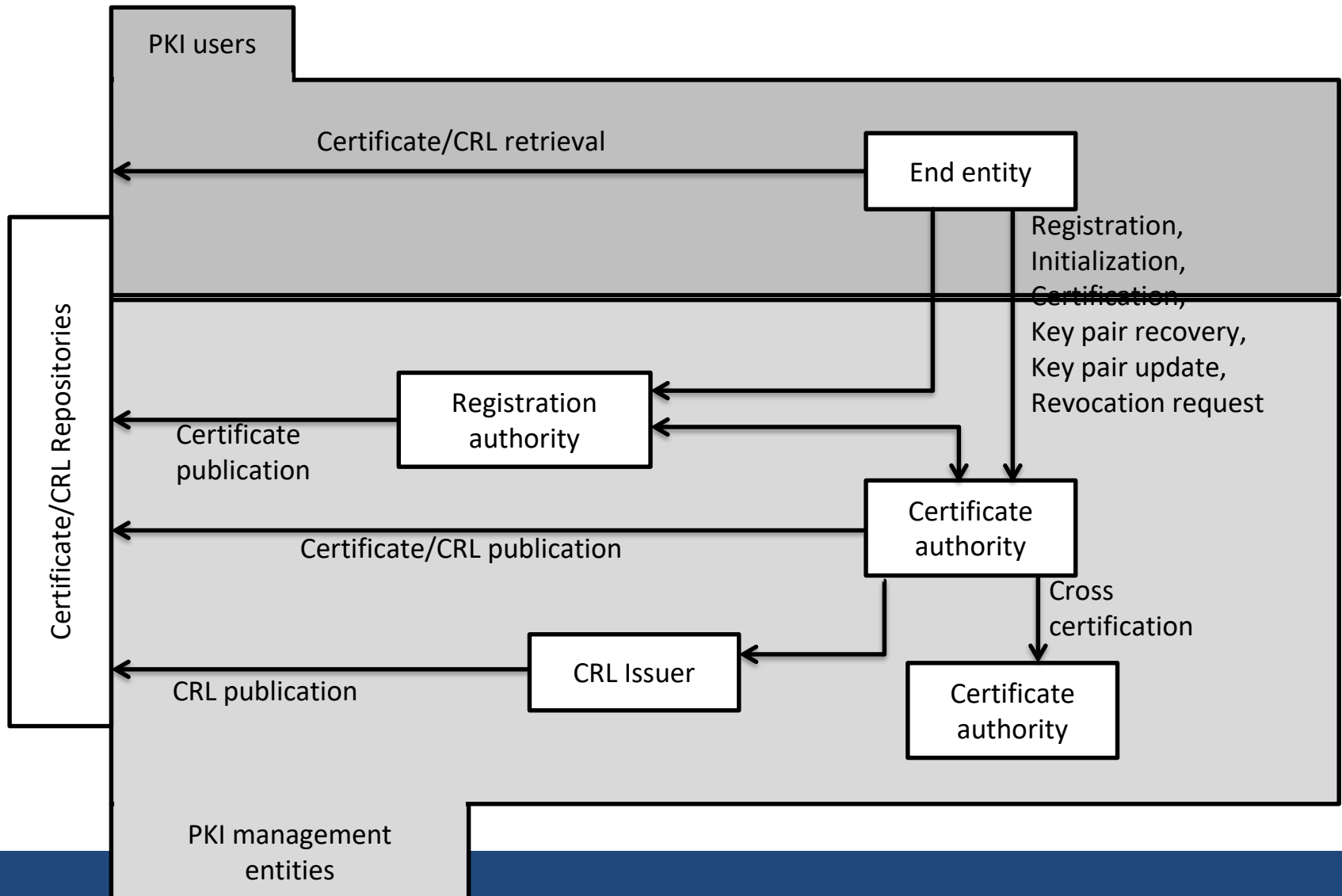
X.509 Certificate

A public-key infrastructure (PKI) is defined as the set of hardware, software, people, policies, and procedures needed to create, manage, store, distribute, and revoke digital certificates based on asymmetric cryptography.

It provides the identification of public keys and their distribution.

The principal objective for developing a PKI is to enable secure, convenient, and efficient acquisition of public keys.

X.509 Certificate



X.509 Certificate

End entity: A generic term used to denote end users, devices (e.g., servers, routers), or any other entity that can be identified in the subject field of a public-key certificate.

Certification authority (CA): The issuer of certificates and certificate revocation lists (CRLs).

Registration authority (RA): CA may use a third-party Registration Authority (RA) to perform the necessary checks on the person or company requesting the certificate to confirm their identity.

CRL issuer: An optional component that a CA can delegate to publish CRLs.

Firewall

- A **firewall** is a security system that monitors and controls incoming and outgoing network traffic.
- It acts as a **barrier** between a trusted internal network and untrusted external networks.
- **Types :**
 - Hardware vs. Software Firewalls
 - Packet Filtering, Stateful Inspection Proxy Firewall
 - Used in both personal and enterprise environments.

Intruder

- Intruders are unauthorized users who try to access systems or data.
Also known as hackers or attackers
- **Types :**
- **External Intruders:** Attack from outside the network.
- **Internal Intruders:** Employees or insiders with malicious intent.
- Use techniques like password cracking and phishing.

Virus

- A virus is a type of malicious software that attaches itself to programs or files.
- Replicates and spreads when the infected program runs
- **Effect and Prevention :**
- Can corrupt files, slow systems, or cause data loss.
- Prevented by using antivirus software and avoiding suspicious downloads.

Trojan

- A Trojan disguises itself as legitimate software.
- Once installed, it gives attackers remote access to the system.
- **Effect and Prevention :**
- Can steal personal data, install more malware, or allow spyware.
- Often spread through email attachments or fake software

Malware

- Malware stands for malicious software.
- Includes viruses, worms, Trojans, spyware, adware, ransomware.
- **Impact and Defense :**
- can cause system crashes, data theft, or financial loss. Use firewalls, antivirus, and practice safe browsing habits.

Ransomware

- Ransomware encrypts a victim's files and demands payment for decryption.
- Delivered via email phishing or malicious downloads..
- **Notable attacks and Protection:**
- Examples: WannaCry, Petya
- Protection: Regular backups, updates, and security awareness.

Parul[®]
University

NAAC
GRADE **A++**



<https://paruluniversity.ac.in/>

